Phishing Detection & Awareness Report

Prepared By: Denise Mutayi

Date: March 2026

Role: Cybersecurity Intern

Organization: Future Interns

---

1. Executive Summary

This report provides a technical analysis of three distinct phishing campaigns identified in 2026. By dissecting email headers and identifying social engineering triggers, this document establishes a risk classification framework and provides actionable prevention guidelines to protect organizational assets from credential theft and Business Email Compromise (BEC).

---

2. Analysis of Phishing Samples

Sample A: The "Microsoft" Account Alert (Credential Harvesting)

- **Subject:** ⚠ Microsoft account unusual signin activity
- **Sender:** Microsoft account team `<no-reply@access-accsecurity.com>`
- **Technical Breakdown:**
  - **Authentication:** SPF/DKIM: **NONE**. DMARC: **PERMERROR**.
  - **Domain Analysis:** Uses a "Look-alike" domain (`accsecurity.com`) to mimic official Microsoft communications.
  - **Tactic: Fear & Urgency.** Forces the user to click a "Verify" link to resolve a non-existent security issue.
- **Risk Classification: CRITICAL**

Sample B: The "Ripple" Allocation Scam (Authorized Spoofing)

- **Subject:** More benefits from Ripple with the Allocation Program
- **Sender:** CoinDesk `<coindesk@mg.areafellowship.com>`
- **Technical Breakdown:**
  - **Authentication:** SPF/DKIM: **PASS**.
  - **Analysis:** The attacker utilized a legitimate third-party mailer (Mailgun) from a separate organization (`areafellowship.com`) to bypass spam filters.

    - **Tactic: Greed/Opportunity.** Leverages the reputation of "CoinDesk" to lure users into connecting crypto wallets to a malicious site.
- **Risk Classification: HIGH**

Sample C: The "Suksapan" Account Hijack (BEC)

- **Subject:** Hi
- **Sender:** `shore@suksapan.or.th`
- **Technical Breakdown:**
    - **Authentication:** SPF: **SOFTFAIL**. DKIM/DMARC: **NONE**.
    - **Analysis:** This is a legitimate organization's account that has been compromised. The attacker is using a trusted `.or.th` domain to send malicious content.
    - **Tactic: Curiosity.** A vague "Hi" subject line bypasses automated keyword filters and encourages the recipient to open the message.
- **Risk Classification: HIGH / SUSPICIOUS**

---

3. Prevention & Awareness Guidelines

The "Safety Checklist" for Employees:

1. **Check the "From" Field:** Look past the name. Is the domain (after the @) exactly what you expect?
2. **The Hover Test:** Hover your mouse over any link. If the URL in the bottom corner of your screen doesn't match the text in the email, **do not click.**
3. **Authentication is not Reputation:** As seen in Sample B, an email can "Pass" technical checks but still be a scam. Always verify the context.
4. **Report Immediately:** Use the internal "Report Phishing" tool to alert the SOC team.

---

4. Conclusion

Technical defenses like SPF and DKIM are vital but not absolute. Security is a shared responsibility; a well-trained workforce acting as "human sensors" is the most effective defense against sophisticated social engineering.